

Guía metodológica para la Encuesta HyVAW-NIS2

1. Objetivo de la encuesta

La presente encuesta tiene como objetivo medir el grado de adopción de flujos híbridos de análisis de vulnerabilidades (HyVAW y metodologías afines) en organizaciones españolas sujetas o alineadas con NIS2, así como su integración con la gestión de riesgos, la resiliencia y los requisitos regulatorios.[web:3][web:16][web:23][web:36] Se pretende obtener una visión estructurada de la madurez nacional y sectorial, identificando brechas, buenas prácticas y oportunidades de mejora.

2. Alcance y población objetivo

La encuesta está dirigida a:

- Operadores de servicios esenciales y entidades importantes según NIS2.
- Organizaciones de sectores críticos no estrictamente NIS2 pero relevantes a nivel nacional.
- Proveedores tecnológicos clave para estos sectores (cloud, servicios gestionados, etc.).[web:21][web:32][web:36]

La unidad de análisis es la organización, si bien la recogida de datos se realiza a través de personas con responsabilidad en ciberseguridad, riesgos, TI o continuidad de negocio.[web:23][web:36]

3. Marco conceptual: HyVAW y análisis híbrido

HyVAW, como metodología, propone un flujo de trabajo de análisis de amenazas y vulnerabilidades para sistemas complejos basados en componentes distribuidos, integrando metodologías previas como STRIDE, CVSS y árboles de ataque en distintas fases.[web:3][web:16] La clave es la combinación de técnicas estáticas y dinámicas, así como la trazabilidad entre componentes, amenazas y contramedidas.

Esta encuesta traduce dicho marco en preguntas que exploran:

- La existencia y calidad de inventarios de activos y modelos de amenazas.
- La realidad de los flujos híbridos (no solo escaneos aislados).
- Las métricas de calidad del análisis (falsos positivos, cobertura, etc.).
- La integración con la gestión de vulnerabilidades, tiempos y priorización.
- La alineación con NIS2 y las guías de ENISA.
- Los resultados operativos y la percepción de madurez y retorno.[web:23][web:36]

4. Diseño de la encuesta

La encuesta se ha diseñado con una mezcla de:

- Preguntas cerradas de opción múltiple para facilitar la cuantificación.
- Escalas tipo Likert (1-5) para medir niveles de madurez y confianza.
- Preguntas de selección múltiple para capturar la variedad de prácticas.
- Preguntas abiertas puntuales para recoger matices cualitativos relevantes.[web:3][web:29]

Se han evitado en la medida de lo posible formulaciones que induzcan respuestas socialmente deseables (nadie quiere admitir que no tiene inventario de activos, pero aquí venimos a la verdad).[web:33]

5. Bloques temáticos y lógica

La encuesta se organiza en ocho bloques:

1.
Datos generales: sector, tamaño, rol. Permite segmentar y comparar por sector NIS2 y dimensión organizativa.[web:21][web:32]
2.
Inventario y modelado de sistemas: verifica la base de cualquier análisis de riesgos y vulnerabilidades, alineada con ENISA y NIS2.[web:23][web:36]
3.
Flujo híbrido de análisis (HyVAW): identifica si existe o no un enfoque orquestado y maduro, frente a prácticas aisladas.[web:3][web:8][web:19]
4.
Métricas de calidad: explora indicadores de falsos positivos, cobertura y eficacia del análisis, clave para dar contenido a NIS2 más allá del mero cumplimiento formal.[web:8][web:19][web:24]
5.
Gestión de vulnerabilidades y tiempos: conecta el análisis con la remediación y los tiempos de respuesta, con referencias a prácticas de NIS2.[web:19][web:23][web:32]
6.
Integración con NIS2 / ENISA: examina el uso de las guías y la existencia de evidencias estructuradas.[web:23][web:36]
7.
Resultados operativos y resiliencia: analiza la relación con incidentes reales, en línea con datos nacionales de INCIBE.[web:32][web:34]
8.
Inversión y ROI: introduce la dimensión económica y estratégica, necesaria para la conversación con la alta dirección.[web:19][web:32]

Datos generales: sector, tamaño, rol. Permite segmentar y comparar por sector NIS2 y dimensión organizativa.[web:21][web:32]

Inventario y modelado de sistemas: verifica la base de cualquier análisis de riesgos y vulnerabilidades, alineada con ENISA y NIS2.[web:23][web:36]

Flujo híbrido de análisis (HyVAW): identifica si existe o no un enfoque orquestado y maduro, frente a prácticas aisladas.[web:3][web:8][web:19]

Métricas de calidad: explora indicadores de falsos positivos, cobertura y eficacia del análisis, clave para dar contenido a NIS2 más allá del mero cumplimiento formal.[web:8][web:19][web:24]

Gestión de vulnerabilidades y tiempos: conecta el análisis con la remediación y los tiempos de respuesta, con referencias a prácticas de NIS2.[web:19][web:23][web:32]

Integración con NIS2 / ENISA: examina el uso de las guías y la existencia de evidencias estructuradas.[web:23][web:36]

Resultados operativos y resiliencia: analiza la relación con incidentes reales, en línea con datos nacionales de INCIBE.[web:32][web:34]

Inversión y ROI: introduce la dimensión económica y estratégica, necesaria para la conversación con la alta dirección.[web:19][web:32]

La lógica interna permite construir índices parciales (por bloque) y un índice global de madurez (IGM) agregando las puntuaciones ponderadas, como se describe en la plantilla de Excel.[web:23][web:36]

6. Procedimiento de aplicación

6.1. Modalidad

Se recomienda la aplicación en formato online (cuestionario web) con:

- Acceso autenticado o enlaces personalizados por organización.
- Posibilidad de guardar y retomar la encuesta.
- Mecanismos de control básico de calidad (campos obligatorios, validación de rango).[web:23][web:36]

Para organizaciones especialmente sensibles, puede ofrecerse versión offline en formato editable (por ejemplo, documento protegido) con posterior carga manual.

6.2. Duración y esfuerzo

La duración estimada para un respondente informado es de 20–30 minutos. Si el lector tarda una hora, no es culpa del cuestionario, sino de alguna revelación interna sobre lo que aún no se tiene controlado.[web:3][web:23]

6.3. Perfil de respondentes

Es recomendable que cada organización designe:

- Un responsable principal (CISO o equivalente).
- Opcionalmente, co-respondentes para bloques concretos (riesgos, continuidad, operaciones).[web:23][web:36]

En caso de respuestas múltiples, debe definirse un mecanismo de consenso interno antes del envío.

7. Tratamiento de datos y construcción de indicadores

Las respuestas se codificarán según el esquema previsto en la plantilla de Excel:

- Cada opción de respuesta se asigna a un valor numérico (p. ej., escala 1–5).
- Algunas preguntas pueden tener pesos distintos según su relevancia normativa o técnica.
- Se construirán índices parciales por bloque y un índice global de madurez (IGM).[web:23][web:36]

Se sugiere:

- Normalizar todos los índices en una escala 0–100 para facilitar su interpretación.
- Calcular percentiles por sector y tamaño de organización.
- Comparar resultados nacionales con referencias europeas cuando estén disponibles.[web:31][web:36]

8. Consideraciones éticas y de confidencialidad

Aunque hablamos de vulnerabilidades y de incidentes, la encuesta:

- No requiere revelar vulnerabilidades concretas ni incidentes identificables.
- Se centra en prácticas, procesos y capacidades, no en “pecados” particulares.[web:23][web:36]

Se recomienda:

- Anonimización de resultados para análisis global.
- Consentimiento informado para cualquier uso externo (informes públicos, benchmarks sectoriales).
- Transparencia sobre quién verá qué y con qué propósito.[web:33][web:36]

9. Uso de resultados

Los resultados se pueden utilizar para:

- Elaborar informes de diagnóstico por organización.
- Generar informes sectoriales y nacionales para autoridades competentes.
- Priorizar inversiones, programas de capacitación y reformas regulatorias.
- Alimentar ejercicios de prospectiva y de stress testing a nivel nacional.[web:23][web:31][web:36]

En resumen, la encuesta es menos un examen y más un espejo. Cada cual es libre de decidir cuánto se mira y qué hace con lo que ve.